

**ESCOLA
SUPERIOR
DE TECNOLOGIA
E GESTÃO**

P.PORTO

Criptografia Aplicada
Public Key Cryptography Standards

Public Key Cryptography Standards

ESCOLA SUPERIOR DE TECNOLOGIA E GESTÃO POLITÉCNICO DO PORTO	ESCOLA SUPERIOR DE TECNOLOGIA E GESTÃO POLITÉCNICO DO PORTO	ESCOLA SUPERIOR DE TECNOLOGIA E GESTÃO POLITÉCNICO DO PORTO
Necessidade	Public Key Cryptography Standard	Formatos de Assinatura Digital

Necessidade

Necessidade

- Public Key Cryptography
 - Public-key cryptography is the technology first identified by Diffie and Hellman in which **encryption** and **decryption** involve **different keys**. The two keys are the **public** key and the **private** key, and either can **encrypt** or **decrypt** data. A user **gives** his or her **public** key to other users, **keeping** the **private** key to himself or herself. Data **encrypted** with a **public** key can be **decrypted only with** the **corresponding private key**, and vice versa.

Necessidade

- O que estandardizar?
 - Para responder à questão descrevem-se quatro tipos de aplicação da criptografia de chave publica:
 - Digital Signature
 - Digital Enveloping
 - Digital Certification e
 - Key Agreement

Necessidade

- Digital Signature
 - Necessidade de especificar:
 - **Sintaxe** para mensagens assinadas digitalmente (independentemente do algoritmo)
 - **Algoritmos** de resumo (digest / hash)
 - **Algoritmos** de chave pública (cifra/assinatura)

Necessidade

- Digital Enveloping
 - Necessidade de especificar:
 - **Sintaxe** para mensagens envelopadas digitalmente (independentemente do algoritmo)
 - **Algoritmos** de chave simétrica (cifra)
 - **Algoritmos** de chave pública (cifra/assinatura)

Necessidade

- Digital Certification
 - Necessidade de especificar:
 - Sintaxe de pedidos de Certificado (Certificate Request)
 - Sintaxe de Certificado
 - Sintaxe de Certificado Extendido
 - Sintaxe de CRL (ou LRC) e OCSP
 - Algoritmos de chave pública (cifra/assinatura)
 - Sintaxe para mensagens assinadas digitalmente

Necessidade

- Key Agreement
 - Necessidade de especificar:
 - Sintaxe de mensagens de Acordo de Chaves
 - Sintaxe de algoritmos de Acordo de Chaves

Public Key Cryptography Standard

PKCS#??

- PKCS#1 – RSA Encryption Standard
 - Definições e recomendações para implementar o algoritmo RSA para criptografia de chave pública
 - Define primitivas criptográficas, esquemas de cifra e assinatura, sintaxe ASN.1 para representação de chaves e identificação de esquemas.
 - É suposto ser utilizado na construção de assinaturas digitais e envelopes digitais (descrito no PKCS#7).
 - PKCS#2 e #4 foram abandonados e incluídos no PKCS#1
- PKCS#2
 - Incluído no PKCS#1 (tal como o PKCS#4)

PKCS#??

- **PKCS#3 – Diffie-Hellman Key Agreement Standard**
 - Standard de Acordo de Chaves Diffie-Hellman
 - Descreve o método para implementar o Diffie-Hellman key agreement, onde duas partes sem acordo prévio podem combinar uma chave secreta entre ambos. Esta chave serve posteriormente para cifrar comunicações (por exemplo)
- **PKCS#5 - Password-Based Encryption Standard**
 - Recomendações para a implementação criptográficas baseadas em passwords que incluem funções de derivação de chaves, esquemas de cifra e esquemas de autenticação de mensagens.
 - Descreve, entre outros, métodos para:
 - cifrar dados com uma chave derivada de uma password.
 - gerar uma chave secreta baseada em passwords
 - É suposto ser utilizado na cifra de chaves privadas quando há necessidade de transferi-las entre sistemas computacionais(descrito no PKCS#8).

PKCS#??

- **PKCS#6 - Extended-Certificate Syntax Standard**
 - Descreve a sintaxe para certificados (v1) estendidos (certificado + atributos) assinados em conjunto pelo emissor do certificado. A ideia desta funcionalidade é estender o processo de certificação para além da chave pública e certificar outros dados/informações. Obsoleto na v3.
 - Uma lista de atributos é descrita no PKCS#9.
- **PKCS#7 - Cryptographic Message Syntax Standard**
 - Descreve a sintaxe geral para dados que podem ser criptografados com assinatura ou envelope digital
 - A sintaxe admite recursividade
 - Permite atributos – hora da assinatura por exemplo – autenticados em conjunto com os dados da mensagem
 - Utilizado também para disseminar certificados (e chave pública) como resposta a um PKCS#10
 - Compatível com Privacy-Enhanced Mail (PEM)

PKCS#??

- **PKCS#8 - Private-Key Information Syntax Standard**
 - Descreve a sintaxe para informação da chave privada incluindo para utilização de algoritmos de chave pública e um conjunto de atributos. Também descreve a sintaxe para chave privada encriptada
 - Utilizado para armazenar/transportar pares de chaves (cifrados ou decifrados)
 - Um algoritmo de cifra baseado em password(PKCS#5) pode ser utilizado para cifrar a informação de chave privada
- **PKCS#9 - Selected Attribute Types**
 - Descreve os tipos de atributos para utilizar no formato:
 - PKCS#6 extended certificates
 - PKCS#7 digitally signed messages e
 - PKCS#8 private-key information
 - PKCS#10 certificate-signing requests
 - Compatível com Privacy-Enhanced Mail (PEM)

PKCS#??

- **PKCS#10 - Certification Request Syntax Standard**
 - Descreve a sintaxe para pedidos de certificados:
 - Um Distinguished Name (DN); chave pública e conjunto de atributos
- **PKCS#11 - Cryptographic Token Interface**
 - Descreve a API (Cryptoki) para os dispositivos que contêm informação e executam funcionalidades criptográficas.
 - O Criptoki (cryptographic token interface) é orientado a objetos e tendencialmente deve ser independente de tecnologias (dispositivos e sistemas operativos) e de recursos partilhados (múltiplas aplicações acedem a múltiplos dispositivos). Disponibilizam às aplicações uma imagem lógica comum do dispositivo chamado token criptográfico.

PKCS#??

- **PKCS#12 - Personal Information Exchange Syntax Standard**
 - Especifica um formato portátil para armazenamento e transporte de chaves privadas, certificados e outros segredos.
 - Muito utilizado para guardar a chave privada juntamente com o certificado (e chave publica) bem como o seu emissor.
 - Dados protegido através de cifra/chave simétrica (PKCS#5 e PKCS#8)
 - Formatos mais comuns: PFX (Windows) e .P12 (Linux, Java, Mozilla...)
- **PKCS#13 - Elliptic Curve Cryptography Standard**
 - Abandonado/Em desenvolvimento
 - Deverá endereçar muitos dos aspetos de criptografia de curva elíptica: parâmetros, geração e validação de chaves, assinatura digital, cifra de chave publica, acordo de chaves e sintaxe ASN.1

PKCS#??

- PKCS#14 - Pseudo-random Number Generation
 - Abandonado
- PKCS#15 - Cryptographic Token Information Format Standard
 - Formato da informação para tokens criptográficos – Standard do formato de credenciais criptográficas em dispositivos criptográficos
 - Estabelece standard que permite aos utilizadores a utilização de tokens criptográficos para autenticação em múltiplas aplicações (mesmo que não sigam outros standards) independentemente do driver do fornecedor do dispositivo (a sua implementação do Cryptoki).
 - Cobre dois grupos de dispositivos:
 - Tokens criptográficos em Hardware
 - Soft-tokens

PKCS#??

- PKCS#??

Standard	PKCS #									External work
	1	3	5	6	7	8	9	10		
<i>Algorithm-independent syntax:</i>										
digitally signed messages					x		x			
digitally enveloped messages					x					
certification requests							x	x		
certificates										X.509, RFC 1422
extended certificates				x			x			
certificate-revocation lists										X.509, RFC 1422
encrypted private-key info.						x	x			
key agreement messages										[ISO90a], [ISO90b]
<i>Algorithm-specific syntax:</i>										
public keys: RSA	x									
private keys: RSA	x									
<i>Algorithms:</i>										
message digest: MD2, 5										RFCs 1319, 1321
secret-key encryption: DES										RFC 1423, [NIST92a]
public-key encryption: RSA	x									
signature: MD2, 4, 5 w/ RSA	x									
password-based encryption			x							
key agreement: D-H		x								

Table 1. Correspondence between aspects suitable for standardization and PKCS.

Formatos de Assinatura Digital

Formatos de Assinatura

- CMS – Cryptographic Message Syntax
 - Sintaxe definida no RFC5652
 - Standard do IETF1 para mensagens protegidas criptograficamente
 - Baseia-se na sintaxe do PKCS#7
 - Utilizado para
 - Assinatura digital
 - Resumo
 - Autenticação e
 - Encriptação

Formatos de Assinatura

- XML-DSig - XML Signature
 - Especifica a sintaxe XML para assinaturas digitais
 - Definida pelo W3C na recomendação [xmldsig-core](#)
 - Similar ao PKCS#7 mas muito mais extensível
 - Detached vs Enveloped (or attached) signature
 - Requer a Canonicalização do XML (c14n):
 - remover espaços, normalização do final de linha,...

```
<Signature>
  <SignedInfo>
    <CanonicalizationMethod />
    <SignatureMethod />
    <Reference>
      <Transforms>
        <DigestMethod>
          <DigestValue>
        </DigestMethod>
      </Transforms>
    </Reference>
    <Reference /> etc.
  </SignedInfo>
  <SignatureValue />
  <KeyInfo />
  <Object />
</Signature>
```

Formatos de Assinatura

- Assinatura Eletrónica Avançada (Advanced Electronic Signature AdES)
 - Assinatura eletrónica que cumpre os requisitos do [regulamento Europeu n.º 910/2014](#)
 - O [signatário](#) deve ser identificado e associado [univocamente](#) à assinatura
 - O signatário tem que ter [controlo exclusivo da chave privada](#) utilizada para a criação da assinatura eletrónica
 - A assinatura deve permitir [detetar qualquer alteração](#) posteriormente efetuada sobre os dados assinados
 - A [deteção de adulteração](#) do conteúdo assinado [deve tornar a assinatura inválida](#)
 - A assinatura pode ter uma das três representações seguintes:
 - XAdES
 - PAdES
 - CAdES

Formatos de Assinatura

- XML Advanced Electronic Signature - XAdES
 - Conjunto de extensões ao XML-Dsig
 - Define 6 perfis que diferem no nível de proteção oferecida:
 - XAdES (também conhecido como XAdES-BES (Basic Electronic Signature))
 - Forma mais básica de assinatura XAdES
 - XAdES-T (timestamp) – adição do campo de timestamp
 - XAdES-C (complete) – adição aos documentos assinados de referências para verificação de dados (certificados e informação de revogação: CRL ou OCSP) que permitam a validação off-line e posterior (future) embora não guarda os dados assinados
 - XAdES-X (extended) – adição de timestamp às referências do XAdES-C o que permite proteção dos certificados contra futuro comprometimento
 - XAdES-X-L (extended long-term) – adição dos certificados e informação de revogação o que permite proteção dos certificados contra future comprometimento mesmo que estes não se encontrem disponíveis
 - XAdES-A (archival) – Adição da possibilidade de aplicação periódica de timestamps (anualmente por exemplo) para prevenção do comprometimento das assinaturas devido à sua fraqueza e exposição quando arquivadas em períodos de longa duração

Formatos de Assinatura

- PAdES - PDF Advanced Electronic Signatures)
 - Conjunto de extensões ao PDF e ISO 32000-1 definidas pelo [ETSI TS 102 778](#)
 - Define 4 perfis que diferem no nível de proteção oferecida:
 - PAdES (também conhecido como PAdES-BES (Basic Electronic Signature)
 - Forma mais básica de assinatura PAdES, baseada em CAdES-BES com opção de assinatura e timestamp
 - PAdES-EPES – Baseado no PAdES-BES mas com adição de identificador de política de assinatura e tipo de compromisso/propósito
 - signature policy identifier and optionally a commitment type indication
 - PAdES-LTV (Long Term Validation) – adição de timestamp à assinatura e certificados
 - PAdES for XML Content – Perfil para armazenamento de assinaturas XAdES embebidas em documentos PDF

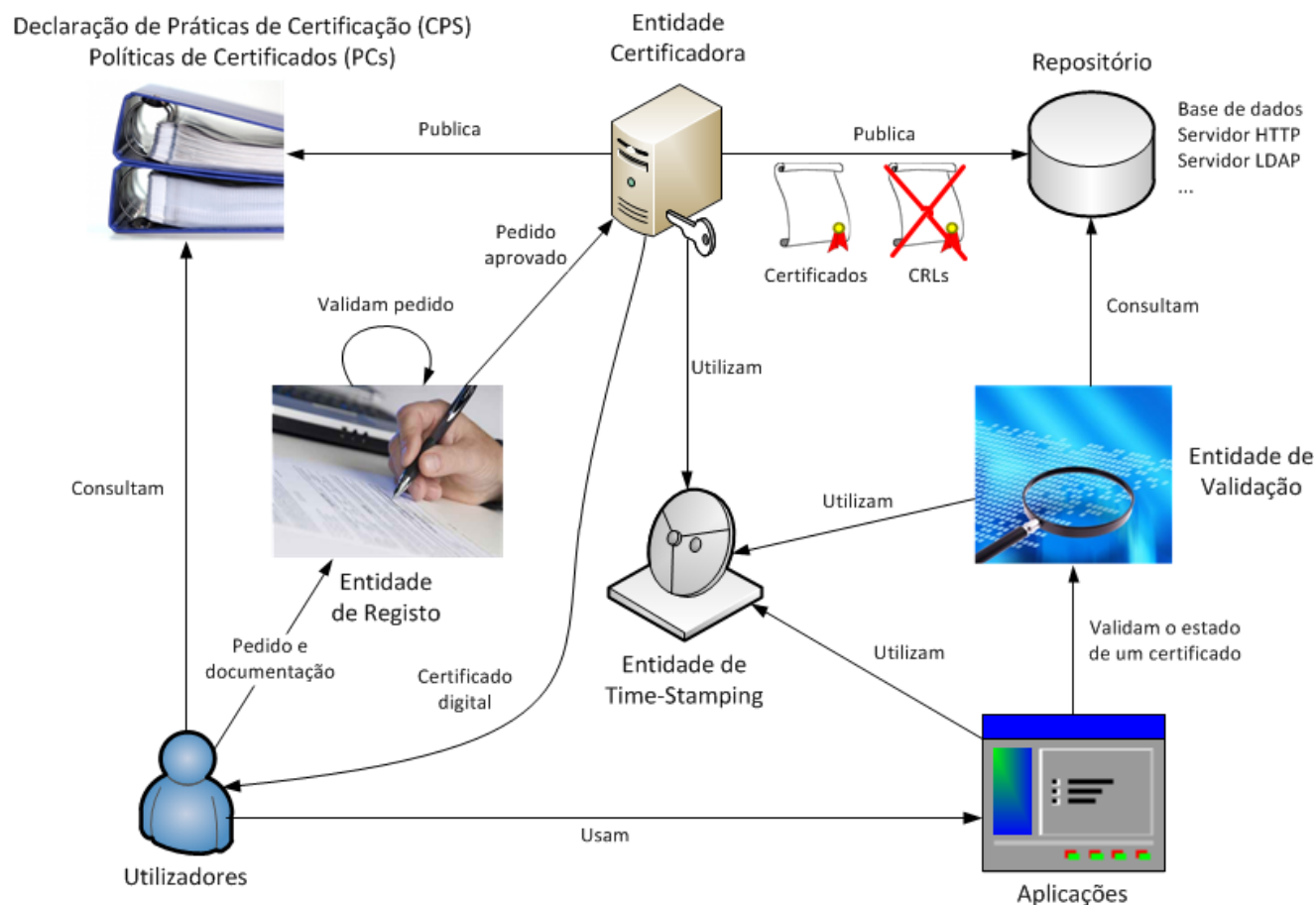
Formatos de Assinatura

- CAdES - CMS Advanced Electronic Signatures
 - Conjunto de extensões ao CMS definidas pelo [ETSI TS 101 733](#)
 - Define 7 perfis que diferem no nível de proteção oferecida:
 - CAdES (também conhecido como CAdES-BES (Basic Electronic Signature))
 - Forma mais básica de assinatura CAdES
 - CAdES-T (timestamp) – adição do campo de timestamp
 - CAdES-C (complete) – adição aos documentos assinados de referências para verificação de dados (certificados e informação de revogação: CRL ou OCSP) que permitam a validação off-line e posterior (future) embora não guarda os dados assinados

Formatos de Assinatura

- CAdES - CMS Advanced Electronic Signatures
 - Cont.:
 - CAdES-X (extended) – adição de **timestamp** às referências do XAdES-C o que permite proteção dos certificados contra futuro comprometimento
 - CAdES-X-L (extended long-term) – adição dos certificados e informação de revogação o que permite proteção dos certificados contra future comprometimento mesmo que estes não se encontrem disponíveis
 - CAdES-A (archival) – Adição da possibilidade de aplicação periódica de timestamps (anualmente por exemplo) para prevenção do comprometimento das assinaturas devido à sua fraqueza e exposição quando arquivadas ao longo do tempo
 - CAdES-LT (long term) – Adição da utilização de algoritmos de “tree-hashing” e “evidence records” RFC4998 (**Deprecated**)

Questões?



Questões?

Forget IPs: using cryptography to verify bot and agent traffic

<https://support.microsoft.com/en-us/topic/secure-boot-certificate-update-status-in-the-windows-security-app-5ce39986-7dd2-4852-8c21-ef30dd04f046>

<https://blog.cloudflare.com/web-bot-auth/>